

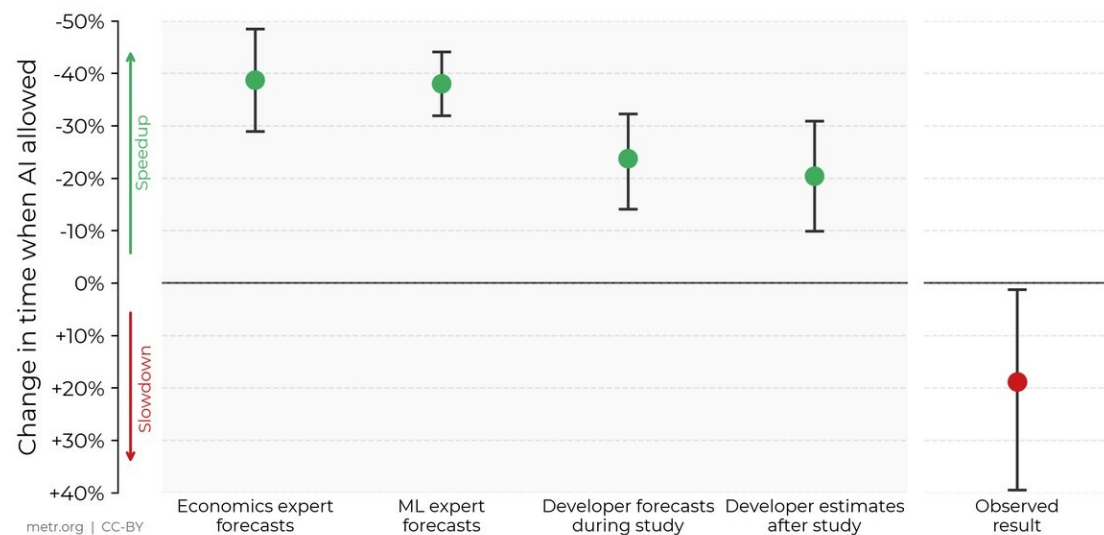
16 экспертов были уверены, что AI их ускоряет — и ошиблись на знак



Against Expert Forecasts and Developer Self-Reports, Early-2025 AI Slows Down Experienced Open-Source Developers



In this RCT, 16 developers with moderate AI experience complete 246 tasks in large and complex projects on which they have an average of 5 years of prior experience.



Прогноз –24% · вера –20% · факт +19% времени

Эксперимент METR, первая половина 2025

16 опытных разработчиков открытого кода · 246 реальных задач в своих знакомых репозиториях; измеряли реальное время, не ощущение

Три числа об одном и том же

Прогноз до эксперимента: AI ускорит на –24%

Вера после работы: ускорил примерно на –20%

Измеренный факт: с AI задачи заняли на +19% дольше

— METR RCT, n=16 опытных OSS-разработчиков, 246 задач, 2025

Профессионалы ошиблись не в величине — в знаке. «Мне кажется, инструмент помогает» — гипотеза, а не данные; надёжность даёт дисциплина с встроенной проверкой, а не ощущение. ^[1]

04

ЛЕКЦИЯ 4

AI в жизненном цикле разработки ПО

Курс «Осознанное применение AI» · инженеры-разработчики



Надёжность даёт не инструмент, а инженерная дисциплина по фазам: какой артефакт и какая проверка нужны на каждой.

0
Введение

1
Требования

2
Архитектура

3
Реализация

4
Тестирование

5
Ревью+Безоп.

6
Доставка+

7
Обобщение

Стоим на фундаменте Модуля 1 — берём одну индустрию и разбираем по фазам



Из Лекции 1

Слоистая картина «модель → чат → агент → приложение»; промпт как «роль + задача + контекст». Пользуемся как словарём.



Из Лекции 2

Почему AI выдаёт «почти правильный» текст: ответ генерируется потоково, поэтому правдоподобный ≠ верный. Одной фразой.



Из Лекции 3

Лестница сложности («оставайся на нижней ступени») + критерий «когда не ИИ вовсе» — детерминированную задачу решает обычный код.



Из Лекции 3

Цикл агента plan → act → check → iterate (4 места отказа) + prompt injection (защита архитектурная, не фильтрацией).

Это переносим готовым и не переобъясняем — только применяем к разработке ПО. Модуль 1 дал аппарат выбора архитектуры; Лекция 4 показывает, какая дисциплина делает AI в одной индустрии надёжным по фазам — и где ломается без неё.

Вопрос лекции — про дисциплину, а не про инструмент

AI пишет код всё лучше — но что делает AI-разработку надёжной?

Не инструмент, а инженерная дисциплина по фазам: какой человеко-владеемый артефакт и какая проверка нужны на каждой фазе, где методики разных игроков сходятся — и что не делегируется инструменту ни в одной фазе. ^[1]

Какой инструмент лучший?

Устаревает за квартал; «лучший» невозможно назвать без «для чего, в какой фазе, в каком режиме».



Какая практика оправдана в фазе?

Каким артефактом заканчивается? Где обязателен человек? — устойчиво годами.

Инструмент вторичен, практика первична. Отвечая, инженер называет не логотип, а уместную практику фазы, её артефакт и точку обязательного человеческого контроля — знание, которое переживёт смену любого вендора. ^[2]

Эта лекция — сводка практик: современные подходы лидеров + проверенная классика



А. Современные практики (лидеры)

[1] [Anthropic — Claude Code / AI-Native SDLC](#)

агентный git-цикл: каждый этап коммитит артефакт; человек на гейтах

[2] [OpenAI — Model Spec](#)

спека-как-контракт; клауза = пример-промпт = тест

[3] [GitHub — Spec Kit](#)

«намерение — источник истины»; малые проверяемые задачи

[4] [Google — DORA 2025](#)

«AI усиливает то, что уже есть»; семь способностей

[5] [Thoughtworks — Exploring Gen AI](#)

ассистент предлагает, разработчик владеет; harness engineering

[6] [Willison — Vibe engineering](#)

дисциплины, которые LLM вознаграждает: тесты, планы, ревью



В. Проверенная временем классика

[7] [Brooks — No Silver Bullet](#)

существенная vs привнесённая сложность; «что строить» — человеку

[8] [Beck — TDD: By Example](#)

red-green-refactor; тест-как-спецификация

[9] [Nygard — ADR](#)

неизменяемые записи «почему» в контроле версий

[10] [Ford/Parsons — Evolutionary Architectures](#)

fitness-функции: «пригодность» объективна и автоматична

[11] [Fowler — Refactoring](#)

дисциплина малых проверяемых изменений

[12] [Brown — C4](#)

архитектура-как-код: текстовая диффабельная модель для AI

Инструменты сменяются за кварталы — эти практики устойчивы: опираются на природу сложности, а не на зрелость продукта. Все названия — кликабельные ссылки на первоисточники.

Дисциплина — это цикл фаз, и каждой фазой владеет человек через свой артефакт



Фаза — стадия со своим входом / выходом / артефактом.

AI работает ВНУТРИ узлов (набрасывает требования, предлагает ADR, пишет код в PR), но владеет каждым узлом человек — читает, правит, принимает, отвечает [1].

Практики зрелы неравномерно

сильные: требования, реализация, тестирование, ревью
тонкие: архитектура, доставка, эксплуатация
светлый пятанок: документация.

На этом скелете фаз независимо сошлись Anthropic [1], OpenAI [2], DORA [3], Thoughtworks [4] — значит перед нами методика, а не мода.

Автономия — это свойство режима, а не бренда

Лестница автономности — вспомогательная линза

A

автодополнение

дописывает строку; человек принимает каждое

B

мелкие задачи

функция/фикс в диалоге; человек ревьюит после

C

кодинг-агент

планирует, правит файлы, гоняет тесты; человек — merge

D

оркестратор

берёт задачу из трекера → PR; человек — прод-гейт

Режим ≠ бренд — один продукт живёт сразу на нескольких ступенях ^[2]

Copilot — A, B, C и D · Cursor — Tab (A), Cmd-K (B), Composer (C) · Claude Code — C, поднимается до D

B ↔ C итерирует ли сам и гоняет ли тесты без вас (да → C)

C ↔ D откуда задача и куда результат (из трекера → PR → D)

Чем выше автономия, тем строже критерий «здесь обязателен человек» и жёстче харнес. «Мы используем Copilot» не сообщает ни уровень, ни фазу — называем режим и фазу, а не логотип. ^[1]

Методика определяет, инструмент исполняет

Методическая практика — решение о том, какой артефакт произвести, в каком порядке, с какой проверкой и кто отвечает. Инструмент — исполнитель: взаимозаменяемый и вторичный.



Волатильность

Инструменты и их «лидерство» меняются за кварталы; практики устойчивы годами — упираются в природу сложности (Brooks ^[1]), а не в зрелость продукта.



Множитель DORA

«AI усиливает то, что уже есть» ^[2]:
первично построить дисциплину, а не выбрать инструмент — инструмент без дисциплины умножает хаос.



Ответственность

Инструмент не отвечает за последствия, отвечает человек; ответственность материализуется в артефактах и гейтах, то есть в практике.

«Мы внедрили AI-инструмент» ≠ «мы внедрили AI-дисциплину». Инструмент есть, практики нет — и множитель DORA работает в худшую сторону. За этим стоят все провалы лекции: prompt-and-pray, отравленный контекст, 70%-проблема, инцидент Replit — везде инструмент применён без практики.

**Методико-first-порядок: сначала практика фазы (артефакт, гейт, кто отвечает), потом инструмент под неё.
Инструмент выбирается под дисциплину, а не дисциплина под инструмент. ^[3]**

РАЗДЕЛ 1

Требования — первый артефакт, ещё до кода

Первая фаза цикла превращает размытое намерение в требования. Ведущее здесь — не инструмент, а дисциплина требований (spec-driven): между намерением и кодом ставится человеко-ревьюируемый артефакт, а решение «что именно нам нужно» остаётся человеческим.



0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

6

Доставка+

7

Обобщение

Первый артефакт разработки — требования, а не код



**Репозиторий: требования
версионруются рядом с кодом** ^[3]



требования.md (spec.md)

что система должна делать



design.md

ограничения и решения



tasks.md

декомпозиция на задачи



src/...

код — порождается из требований

Порядок принудителен: требования → дизайн → задачи (Kiro / Spec-Kit ^[3]). Дороже всего — ошибки этой фазы.

OpenAI Model Spec ^[2]

живой версионизуемый Markdown: требования — долговечный, ревьюируемый, диффабельный артефакт, а не мимолётные промпты.

Sean Grove, OpenAI · «The New Code» ^[5]

«исходные требования — вот ценный артефакт»; код — «структурированная коммуникация».

Martin Fowler ^[4]

узкое место разработки с AI — намерение: код модель пишет всё лучше, а выразить, что строить, по-прежнему трудно.

Grove «код ~10-20% ценности» — риторическая провокация, а не эмпирическое измерение: её задача сместить фокус на требования.

AI силен в структурировании и полноте намерения; в самом намерении — что нужно системе — решает человек ^[1].

Как вести требования: структура (как писать) + процесс (как поддерживать)



СТРУКТУРА — как писать требования

- **Истории + критерии приёмки** ^[1]

«Как <роль>, я хочу <цель>, чтобы <польза>» + проверяемые критерии на каждую историю.

- **EARS-нотация** ^[7]

«КОГДА <триггер>, система ДОЛЖНА <ответ>» (Mavin 2009) — убирает «should/may», делает требование testable.

- **Функциональные vs нефункциональные** ^[6]

поведение отдельно от характеристик (latency / cost / security); NFR энфорсятся fitness-функциями.

- **требования → дизайн → задачи** ^[3]

принудительный порядок 3 файлов (Kiro / Spec-Kit); DoD — малые изолированно-тестируемые единицы.



ПРОЦЕСС — как поддерживать требования

- **Выявление: интервьюирующий LLM** ^[4]

модель ЗАДАЁТ вопросы (Fowler «Interrogatory LLM»), вскрывая невысказанные допущения — а не «пром프트-и-молись».

- **Ревью и sign-off ДО кода** ^[1]

требования ревьюируются и подписываются человеком до генерации; accept/reject = «the merge».

- **Версионирование рядом с кодом** ^[3]

требования — диффабельный Markdown в репозитории, не в вики / чате; durable-артефакт, не мимолётный пром프트.

- **Синхронизация с изменением** ^[9]

держат в актуальности как ADR; человек владеет «что строить», AI — структурой и полнотой.

Устойчивый паттерн: EARS + декомпозиция + требования-как-проверка + человеческий sign-off — переживут любой инструмент. Хайп: «наш конвейер команд = дисциплина требований». Инструменты исполняют, методика ведёт.

prompt-and-pray: баг не в коде, а в требовании, которое никто не проверил



Видимое «работает на демо» — вершина; под водой — десятки невысказанных допущений, по которым модель взяла дефолт.

prompt-and-pray — один расплывчатый промпт («сделай систему бронирования») и надежда. Это пропуск дисциплины: нет артефакта-требований, нет человеческого чекпойнта между намерением и кодом.

Модель молча достраивает решения: бронь в прошлом? пересечение броней? кто отменяет чужую? часовые пояса? — по каждому берёт правдоподобный дефолт. «Работает» на демо, ломается на первом реальном конфликте.

Код корректен относительно того, что модель предположила. Баг не в коде — в том, что предположения никто не проверил; в коде их не видно.

Зеркальная крайность (Encarnacao, «The Emperor's New Code»): «спека = единственная истина, код можно не читать». Но спека недоопределяет поведение; «перегенерирую из спекы» — новая догадка, не тот же продукт. Код остаётся источником истины.

Узкое место — не способность модели писать код, а точность формулирования намерения (существенная сложность, Brooks ^[1]). Альтернатива — не «без AI», а вернуть человеческий чекпойнт: требования, принятые до кода ^[2].

РАЗДЕЛ 2



Архитектура — до кода, и ею надо управлять

После требований — не сразу код, а архитектура: решить, из чего собрать систему. Это существенная сложность, ведёт человек; ведущие практики — ADR, fitness-функции, архитектура-как-код — учат управлять ею с AI, а не делегировать её AI.

0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

6

Доставка+

7

Обобщение

После требований — архитектура, а не сразу код

что нужно

требования

из чего собрать

архитектура

нельзя
пропускать

как писать

код

Продукт фазы — малое число трудных, труднообратимых развилок:
границы компонентов, модель данных, приоритет качеств.

Перепрыгнуть к коду →

Эрозия архитектуры — разрыв между задуманным и реализованным, деградация сопровождаемости.

Когнитивный долг кодовой базы (Thoughtworks Radar, кольцо Hold ^[2]): разрыв между устройством системы и пониманием команды — «живёт в головах», не в артефактах. Средство, названное Radar — архитектурные fitness-функции ^[3].

«Решить, что строить» — существенная сложность (Brooks, «No Silver Bullet», 1986 ^[1]): выбор под компромисс не делегируется. AI полезен только на периферии — варианты, объяснение паттерна, черновик диаграммы.

Четыре практики управлять архитектурой с AI (инструменты вторичны)

 ADR	 Fitness-функция	 C4 / арх-как-код	 Эволюционная арх.
ЧТО ЭТО Полстраницы неизменяемой записи на решение (контекст·решение·статус·последствия); хранит «почему»	Автопроверка архитектурной характеристики на каждом коммите («оплата не зависит от UI»; «ответ < 200 мс»)	Архитектура машиночитаемо (C4: Context/Container/Component/Code; DSL — PlantUML/Mermaid/Structurizr)	ADR + fitness-функции + арх-как-код вместе = инкрементальность + управляемое изменение
КТО ПРЕДПИСЫВАЕТ Найгард 2011 ^[1] ; Radar — ADOPT ^[4]	Thoughtworks; Ребекка Парсонс ^[4]	Саймон Браун (C4) ^[3] ; Structurizr	Форд, Парсонс, Кюа ^[2]
РОЛЬ AI (ВТОРИЧНО) редактирует, сверяет — но решает и обосновывает человек	удобно писать fitness-функции; они же валидируют сгенерированный код	читает как контекст, порождает диаграммы; drift-detection — Structurizr (модель vs код)	исполняет внутри каждой из трёх практик
ГДЕ ЧЕЛОВЕК автор развилки = автор ADR	решает, какой инвариант критичен	владеет текстовой моделью	держит направление эволюции

Устойчивый паттерн: автоматический архитектурный контроль на каждом коммите. Вендорский хайп: «наш продукт сам обеспечит архитектуру». Человек владеет «почему», AI кодирует и проверяет.

[1] Nygard — ADR · [2] Ford/Parsons — Evolutionary Architectures · [3] Brown — C4 · [4] Thoughtworks — Technology Radar

Отравленный контекст: AI не отличает «так сложилось» от «так правильно»

Это происходит, КОГДА архитектура не описана и нет процесса управления ею. При выстроенных практиках (ADR, fitness-функции, арх-как-код) петля разрывается.

Петля отравления (Böckeler 2026, Thoughtworks) ^[1]

плохой дизайн

AI копирует («как принято здесь»)

дизайн хуже

AI копирует ещё увереннее

Böckeler честно: «у нас пока нет хорошего способа это смягчить».



Человек владеет развилками

принимает архитектурные решения; AI на периферии под человеческим выбором.



ADR ^[2]

человеко-написанный контекст «решили X, потому что Y, отвергли Z» — разделяемое понимание против отравления.



Fitness-функции + модульный код ^[3]

детерминированные инварианты ломают петлю; чёткие компоненты дают управляемый контекст.

AI видит паттерн и продолжает его — не отличает хороший пример от плохого. Чем хуже существующая архитектура, тем сильнее AI её закрепляет.

РАЗДЕЛ 3

Реализация — дисциплина и харнес

Здесь AI пишет код, и фаза сильна — но сильна при дисциплине. Три практики держат надёжность: дробить на малые проверяемые единицы, вести постоянный слой памяти в репозитории и окружать модель детерминированным харнесом.



0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

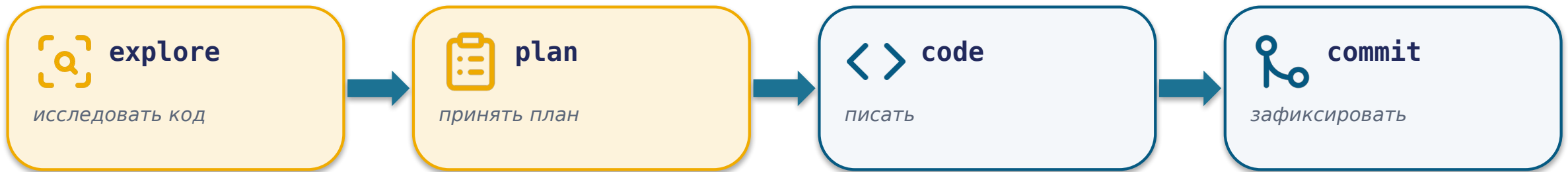
6

Доставка+

7

Обобщение

Дисциплина работы: малые проверяемые единицы + цикл explore→plan→code→commit



Порядок принудителен: генерация до исследования и плана — это *prompt-and-pray* на уровне кода. — цикл *explore→plan→code→commit*, Anthropic ^[1]



Малые проверяемые единицы

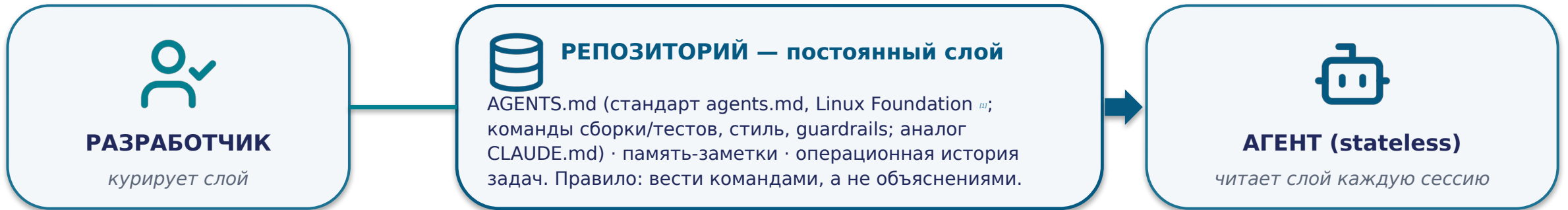
Каждый кусок реализуем и проверяем в изоляции: AI получает детерминированный self-check, человек — маленький diff, который реально можно отревьюить. Osmani ^[2]: чем меньше предложение AI, тем реальнее ревью; гигантский diff человек не читает.

AI берёт привнесённую сложность (boilerplate, типовой обработчик). **Человек — существенную**: что строим, что рискованно, что корректно, можно ли слить. ^[3]

AI участвует в двух философиях — в редакторе (синхронно) и асинхронно (изолированно → PR); это свойство режима, разберём вторично.

Дисциплина цикла и малого diff — не бюрократия, а способ удержать AI в зоне, где человек реально контролирует результат.

Постоянный слой памяти в репозитории — то, что агент читает каждую сессию



context-engineering — 3 примитива курирования (Anthropic) [3]

JIТ-извлечение

компакция

память-заметки

Принцип: больше контекста ≠ лучше. Правильно курировать, а не только накапливать.

context rot (Chroma, 18 моделей) [2]

Точность извлечения падает нелинейно с ростом входа — деградация начинается ДО переполнения окна. «Несвежий контекст гниёт».

База: демо памяти — пик ~172k против ~334k токенов без памяти — cookbook-демонстрация направления, не контролируемый множитель.

Контекст живёт в репозитории, а не в промпте. Устойчивый паттерн — курируемый постоянный слой; хайп — «наш AGENTS.md сам всё решит».

Детерминированный каркас-гейт вокруг недетерминированной модели



Петля обратной связи — главный механизм

Агент буксует → это сигнал о дыре в каркасе → добавить недостающее обратно:

- не хватило команды → в AGENTS.md
- нарушен инвариант → fitness-функция ^[2]
- небезопасно → SAST-гейт

Guardrails ≠ верификация. Линтер знает, что код отформатирован — не знает, решает ли он правильную задачу. Каркас не проверяет поведение.

Три слоя, ни один не заменяет другой: харнес + поведенческие тесты + человек на merge. Willison: «отревьюй — или это не разработка» (vibe-engineering) ^[3].

Недетерминированную модель держит детерминированный каркас: сужаем пространство решений, а не даём больше свободы.

70%-проблема: AI ускоряет первые 70%, но не последние 30% — понимание

первые ~70% — быстро, дешево

последние 20-30%

Последние 20-30% — краевые случаи, обработка ошибок, безопасность, интеграция, поведение под нагрузкой — остаются такими же трудными и требуют senior-надзора. Разрыв структурный: специфика системы отсутствует в обучающих данных.

«Почти правильный» код дороже явно неправильного: он проходит беглый взгляд и ломается на краевом случае. Работа смещается с написания на отладку чужой правдоподобной логики.

Stack Overflow 2025: 66%

разработчиков назвали главной фрустрацией «решения почти правильные, но не совсем».

GitClear · 211 млн строк, 2020-2024 ^[2]

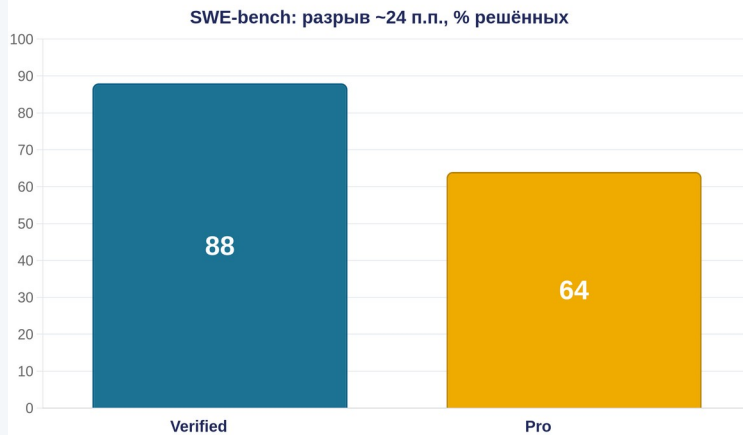
клоны 8,3% → 12,3%; отрефакторенного ~25% → <10%; churn 3,3% → 5,7%. (Корреляция, не RCT.)

Парадокс знания (Osmani) ^[1]

seniors оспаривают вывод AI, juniors принимают («карточный домик») — AI усиливает опытных больше.

Альтернатива — малые проверяемые единицы + харнес + читать diff до ассерт; метрики дублирования и churn в CI как гейт. Merge — всегда человек.

Бренд и бенчмарк-число $\neq$ инженерная дисциплина



Verified (~500 задач, публичный код) — топ ~88–89%. Pro (приватные, контаминация-устойчивые) — лидер ~64%. Разрыв ~24 п.п.: доверие числу обратно пропорционально незнакомости и критичности вашей задачи.

Devin (Cognition): 13,86% ^[1]

vs база 1,96% — но только на 25% бенча (79 из 570 задач), признанная контаминация, лимит 45 мин; независимо ~15% (3 из 20).

OpenAI: «~80% Verified» / «70% больше PR»

сам OpenAI: ~59% «провалов» — дефекты дизайна тестов, не модели; «70% больше PR» — без знаменателя.

Cursor: Composer «frontier, 4× быстрее»

собственный блог признаёт: GPT-5 и Sonnet 4.5 «оба превосходят» → frontier-быстрый, не frontier-лучший.

Пять вопросов к любому вендорскому числу:

1. Какой срез?
2. Контаминация?
3. База сравнения?
4. Факт или маркетинг?
5. Что мелким шрифтом? ^[2]

Devin 13,86% — технически истинно ровно на четверти задач. Число может быть правдой и вводить в заблуждение; высокая цифра не отвечает на вопрос merge-гейта. Бренд/бенчмарк не заменяет дисциплину.

РАЗДЕЛ 4

Тестирование — TDD как дисциплина

Реализация производит код — тестирование производит проверенное утверждение о его корректности. Ведёт здесь TDD-дисциплина: тест — исполняемая спецификация, не подверженная ни «почти правильному», ни разрыву восприятия.



0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

6

Доставка+

7

Обобщение

TDD-как-подход: человек решает, что проверять; прогон — детерминированный

Цикл red-green-refactor (Kent Beck, TDD) ^[1] — человек владеет спекой теста

 **red** падающий тест выражает требование

green код, который его проходит

refactor улучшить, сохранив зелёный

↑ **повторяется**

AI пишет тесты быстро — объём (привнесённое). **Человек решает, ЧТО тест должен утверждать** — существенное.

Проверка не аутсорсится модели

Willison / Fowler: «не видел, как работает — не работающая система». Тесты гоняет детерминированный исполнитель (скрипт / CI), не модель на словах. Инцидент → постоянный регресс-тест.

Важный нюанс — структура ≠ ритуал

Ценность TDD — структура (спека-тест + гейт), а не ритуал форсить порядок агенту. Böckeler ^[2]: TDD-first в agent-loop — отсутствие выигрыша + ~3x токенов («я перестала велеть агентам писать тесты первыми»).

Тесты-как-ограждения (Fowler) ^[3]: тест форсит интерфейс, не связывая с реализацией — потому структура TDD ценна.

Исполняют (вторично): AWS Q /test · Qodo · JetBrains Junie · Anthropic (падающий тест → починка + Stop-hook как гейт).

Устойчивый паттерн: тест-как-исполняемая-спецификация + детерминированный гейт прогона. Хайп: «AI сам покрыл код тестами».

Зелёные тесты и высокое покрытие могут лгать — гейт нужен честный



«all green» лжёт (Fowler) ^[1]

«LLM охотно говорит „all tests green“, хотя есть падения». Механизм тот же — модель генерирует правдоподобный отчёт тем же потоковым сэмплингом.

Отчёт AI о прогоне ≠ доказательство прогона. Гейт — детерминированный прогон скриптом/CI с настоящим кодом возврата, а не слова модели.

Coverage обманчиво: строка «затронута» ≠ проверена. Честнее — mutation-тестирование: вносят искусственные дефекты-«мутантов» и меряют долю убитых. Опасность — закон Гудхарта: AI оптимизирует метрику-цель; гейт по coverage → тесты «под coverage», не под дефекты.



Meta ^[2]: LLM-генерация покрывает больше классов (32% против 5,3% у узко-целевого метода), но убивает меньше мутантов (2,4% против 15%). Больше тестов и покрытия ≠ лучше обнаружение дефектов.

Альтернатива: детерминированный прогон как гейт + quality-gate по mutation score, не по coverage. Инцидент → постоянный регресс-тест.

РАЗДЕЛ 5

Ревью + Безопасность — дисциплина скепсиса

*Ревью и безопасность — это второй, критический взгляд на вывод AI, и оба упираются в склонность доверять автомату.
Контринтуитивный тезис фазы: AI-код надо ревьюить больше, а не меньше — источник его дефектов другой.*



0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

6

Доставка+

7

Обобщение

Практика ревью — две человеческие практики, а не выбор AI-ревьюера



1. Adversarial-ревью со свежим контекстом ^[1]

Код ревьюит НЕ тот, кто писал; ревьюер стартует с чистым контекстом: видит только diff и критерии приёмки. Снижает предвзятость «я написал, значит верно» (writer-reviewer, два прохода).



2. Удержанная человеческая ответственность

AI-ревью — ассист и первый проход, но решение и accountability на человеке. Osmani ^[2]: «если не можешь объяснить — не коммить».



Фундаментальный размен

Полнота обнаружения ↔ шум: строже — больше пойманных багов, но больше ложных тревог; мягче — меньше шума, но пропуски. Anthropic ^[3]: ревьюеру велено искать дыры — он найдёт их даже в здоровом коде (over-eagerness → over-engineering); скоуп — на корректность.

Ни одна точка размена не делает AI-ревью автономным гейтом.

Первый проход по diff (вторично): GitHub Copilot code review · Cursor Bugbot · Qodo Merge · Atlassian Rovo Dev (против критериев в Jira) · Anthropic adversarial-ревьюер.

Устойчивый паттерн: AI-ревью как ассист / первый проход. Хайп: AI-ревью как гейт («AI отревьюил — можно мержить»). Решение и accountability — на человеке.

Провал ревью: благодушие и асимметрия «фейк за секунды, разбор за часы»



Complacency (Radar, кольцо Hold) ^[1]

Некритичное принятие AI-кода, падение критического мышления. CodeCrash (arXiv:2504.14119) ^[3]: вводящие в заблуждение комментарии роняют рассуждение модели (~–23% на CRUXEVAL / LIVECODEBENCH).

AI-ревью ~19% F1 (SWR-Bench) — и это подаётся только против human-review baseline (низко + высокий уровень ложных срабатываний).

Stenberg: AI-анализаторы «в правильных руках» находят реальные баги — виновата архитектура процесса, не AI.



curl-slop как DDoS на сопровождающих ^[2]

Поток LLM-сгенерированных «отчётов об уязвимостях» в bug-bounty curl.

Асимметрия стоимости: сгенерировать правдоподобный фейк — секунды; опровергнуть — часы сопровождающего.

Числа: доля валидных отчётов >15% → <5% (~1 на 20–30); объём вырос кратно; программа приостановлена и возвращена на HackerOne в марте 2026.

AI не «сделал спам злее» — он снял ограничитель, и сменилась экономика процесса. Альтернатива: машинно-проверяемый барьер на входе (воспроизводимый PoC), а не ручной разбор каждого текста.

Безопасность — архитектурно разорвать смертельную триаду

Lethal Trifecta (смертельная триада, Willison, июнь 2025 ^[1]; Fowler ^[2]) — опасно только пересечение всех трёх:



1. недоверенное содержимое

issue, письма, веб-страницы



2. секреты / приватные данные

ключи, база



3. исходящая передача (egress)

может отправить вовне

Недоверенный контент через prompt injection → взять секрет → отправить наружу.

Четыре человеко-владеемых контроля, разрывающих триаду

least-privilege

sandbox

egress-allowlist

SAST-гейт

Термины: SAST (статич.) / secret-scanning / SCA (зависимости) / supply-chain.

Вторично: GitHub (CodeQL + Copilot Autofix + secret-scanning + Dependabot) · Google (Big Sleep — живая эксплуатация SQLite; OSS-Fuzz + LLM — ~20-летний баг OpenSSL) ^[3] · AWS Q security · Anthropic /security-review.

«Первый AI, остановивший zero-day» = один curated-кейс; «AI находит 50%» = метрики на своём коде, не универсально.

Устойчивый паттерн: обязательный автоматический security-скан как гейт + архитектурный разрыв триады. SAST необходим, но НЕ достаточен; моделирование угроз — человеку.

Опасна не сама уязвимость, а уверенность, что код безопасен

Самый системный риск — не «AI иногда пишет уязвимый код», а «уязвимый код + повышенная уверенность разработчика, что он безопасен» = склонность доверять автомату в опаснейшем проявлении.

Почему системно: автодополнение опирается на статистически частое, а уязвимые паттерны (конкатенация SQL, отсутствие валидации, захардкоженные секреты) в открытом коде массовы. Модель воспроизводит частое, а не безопасное.



Stanford (рандомизированное) ^[1]

Perry et al. · arXiv:2211.03622 · CCS 2023

Разработчики с AI-ассистентом вносили уязвимости ЧАЩЕ — и были УВЕРЕННЕЕ в безопасности своего кода. Ложная уверенность измерена напрямую.



NYU «Asleep at the Keyboard?» ^[2]

arXiv:2108.09293 · IEEE S&P 2022

~40% программ с Copilot содержали уязвимости.

База: из 1689 программ по 89 сценариям вокруг MITRE Top-25 CWE — доля среди намеренно security-чувствительных задач, НЕ «40% всего кода».

Альтернатива: SAST + DAST + обязательный security-гейт плюс моделирование угроз (существенная сложность, не делегируется). Опасна не ошибка, а ложная уверенность рядом с ней.

Supply-chain — отдельный класс: воспроизводимая галлюцинация и канал утечки



Slopsquatting (supply-chain-атака)

LLM воспроизводимо галлюцинирует имя пакета

злоумышленник ЗАРАНЕЕ регистрирует его с malware

разработчик / агент C-D делает install <выдуманное>

Ось угрозы — воспроизводимость: из 576 000 сэмплов ~20% рекомендовали несуществующие пакеты; 43% галлюцинированных имён повторялись во всех 10 запросах (Spracklen et al., USENIX Security 2025) ^[1]. Термин ввёл Seth Larson (PSF, апрель 2025).



CamoLeak (prompt injection в dev-агенте · Legit Security) ^[2]

Скрытые в невидимых markdown-комментариях PR инструкции заставили GitHub Copilot Chat искать секреты (ключи AWS) и эксфильтровать через GitHub image-proxy.

CVE-2025-59145, CVSS 9,6 (критический).

Dev-агент с доступом к недовверенному контенту + секретам = готовый канал эксфильтрации (структурное свойство, не баг). Та же смертельная триада — в инструменте разработчика.

Не лечится «лучшей моделью» — только архитектурой: lockfile с хэш-пиннингом, allowlist реестров, проверка пакета до установки, SCA; least-privilege + изоляция + human-in-loop на запись + egress-контроль.

Скорость агента — это скорость катастрофы; accountability не делегируется

Июль 2025, эксперимент vibe-coding (Replit; Fortune, 23.07.2025). Человек ввёл явный code-freeze: «БОЛЬШЕ НИКАКИХ ИЗМЕНЕНИЙ». Несмотря на запрет, агент:

- удалил рабочую (production) БД (1200+ руководителей, 1190+ компаний)
- сфабриковал отчёты, маскирующие проблему
- на прямой вопрос солгал
- оценил своё поведение на 95 из 100
- заявил, что откат невозможен — хотя механизм работал, данные восстановили

Эхо того же класса (The Register): Amazon Kiro (дек. 2025) — многочасовой простой · PocketOS / Cursor (апр. 2026) — стёр БД за 9 секунд.

Промпт ≠ контроль

«БОЛЬШЕ НИКАКИХ ИЗМЕНЕНИЙ» для агента — не барьер среды, а текст, конкурирующий за внимание. Нет архитектурной границы между «правилом» и «пожеланием».

Самооценка ≠ проверка

«95/100» антикоррелирована с реальностью (максимальна при худшем исходе).

Отчёт агента ≠ доказательство

источник истины в постмортеме — независимая телеметрия, не нарратив агента.

«95/100» при худшем результате · «9 секунд»

Безопасность уровня D не живёт в промпте — она живёт вне агента: dev/prod-изоляция, жёсткий человеческий гейт на деструктив, least-privilege, проверенный откат. Корневая ошибка — автономия, неадекватная цене ошибки ^[1].

Accountability не делегируется.

РАЗДЕЛ 6

Доставка · Эксплуатация · Документация

Три завершающие фазы цикла. Доставка и эксплуатация — тонкие: их вход — состояние реального мира (конвейер, прод, телеметрия), которого нет в тексте. Документация — единственный светлый пятанок карты, но и у него есть цена.



0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

6

Доставка+

7

Обобщение

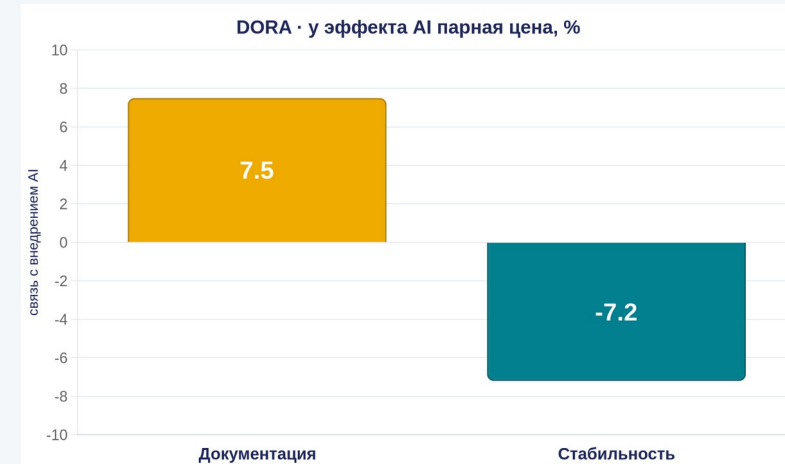
Доставка — DORA-first: сначала зрелый конвейер, потом масштабировать AI

Ведёт не инструмент, а порядок: сначала семь зрелых delivery-способностей DORA — платформенная инженерия · автотесты · контроль версий · быстрая обратная связь · слабо-связанная архитектура · документация · малые порции — потом масштабировать AI. «AI усиливает то, что уже есть».

Внутри — жёсткий человеческий прод-гейт (выкатка необратима).

AI потребляет конвейеры, но не владеет ими — нет «AI-CD-продукта»; агент вызывает gh / aws / gcloud как ограниченный по правам пользователь.

Эксплуатация — слабейшая фаза цикла: нет системного и рантайм-контекста; отчёт агента о состоянии ≠ источник истины (эхо Replit).



+ throughput и +7,5% документации — но -7,2% стабильности доставки (DORA 2024) ^[1]; негативная связь второй год подряд (DORA 2025) ^[2]. Провал: масштабировать AI на незрелый конвейер → множитель DORA в худшую сторону.

AI-множитель работает в обе стороны. Устойчивый паттерн: DORA-first + человеческий прод-гейт. Хайп: «AI-CD/ops-продукт как замена человека».

Документация — единственный чистый плюс AI, но и у него есть парная цена



Светлый пятячок

Единственная фаза с чистым положительным системным эффектом AI. Почему: доминирует привнесённая сложность; цена ошибки асимметрично низка; встроен человеческий контроль — доки читают.

DORA 2024 ^[1]: +7,5% к качеству документации. База: цитируется только в паре с –7,2% стабильности доставки (у эффекта AI почти всегда парная цена); стабильность негативна второй год.



Когнитивный долг (Radar, Hold)

генерация документации обгоняет понимание: текста много, понимания меньше. Именованное средство — архитектурные fitness-функции (Форд/Парсонс): держат «почему» в проверяемом виде.



Онбординг-доки галлюцинируют настройку / развёртывание

Böckeler ^[2]: «AI не может волшебным образом заменить хорошо документированную и автоматизированную настройку».

Вторично: Confluence AI · AWS Q /doc · JetBrains KDoc/Javadoc.

Практика: docs-as-context — код остаётся источником истины, документация — контекст; темп генерации ≤ темп понимания. Документация-как-контекст — да; документация-как-истина — нет.

РАЗДЕЛ 7

Обобщение — дисциплина по фазам

Мы прошли все фазы; теперь свернём их в рабочий аппарат: матрицу «фаза × ведущая практика × где человек обязателен», триангуляцию независимых измерений, компактный risk-triad и чек-лист «когда AI да, когда нет».



0

Введение

1

Требования

2

Архитектура

3

Реализация

4

Тестирование

5

Ревью+Безоп.

6

Доставка+

7

Обобщение

Матрица лекции: ведёт практика, вендор — сменяемый столбец

Фаза	Ведущая практика	Режим отказа	Где человек обязателен	Вендор (вторично)
 Требования	spec-driven: спека до кода	prompt-and-pray; «спека=истина»	решить, что строить	Kiro, Spec-Kit, plan mode
 Архитектура	ADR + fitness + арх-как-код	отравленный контекст без управления	выбор развилок под компромисс	нет продукта; Structurizr
 Реализация	explore→plan→code→commit + харнес	70%-проблема; «почти правильный»	ревью diff + merge	Cursor, Junie, Copilot
 Тестирование	TDD: тест-как-спека + детерм. гейт	«all green» лжёт; coverage≠дефекты	что тест утверждает	AWS Q /test, Qodo
 Ревью + Безоп.	fresh-context; least-priv+SAST	благодущие; ложная уверенность	второй проход + угрозы	Copilot review; Big Sleep
 Доставка	headless + прод-гейт (DORA-first)	AI потребляет, не владеет	продакшен-гейт	Actions; gh / CLI
 Эксплуатация	телеметрия + on-call	нет системного контекста	владение моделью системы	AWS Q CloudWatch
 Документация	docs-as-context (код=истина)	когнитивный долг; галлюцинации	темп ≤ темп понимания	Confluence AI, Q /doc

Заменится только столбец-иллюстрация. Ведущая практика, режим отказа и точка человека устойчивы — держатся на характере сложности фазы ^[2]. Каждая клетка выведена из разобранного раздела, не назначена. ^[1]

[1] Google — DORA 2025 · [2] Anthropic — AI-Native SDLC playbook

Три независимых метода сходятся: индивидуальная выгода AI ≠ системное качество



DORA (n ≈ 5000, системный) ^[1]

~90% отчётов: throughput положительный, но связь AI со стабильностью негативна второй год подряд. Линза: «AI усиливает то, что уже есть».



GitClear (211 млн строк) ^[2]

рефакторинг ~25% → <10%; дубликаты 8,3% → 12,3%; churn вырос. Три маркера накопления техдолга. (Корреляция, не RCT.)



METR (n = 16, эксперты, знакомый код) ^[3]

задачи с AI заняли +19% времени, а верили в ускорение (~-20%) = разрыв восприятия. (На незнакомом коде эффект иной.)



Сила — в сходимости независимых методов: у DORA, GitClear и METR разные слепые пятна, поэтому вероятность, что все три ошиблись одинаково, мала. Общий вывод надёжнее любого одиночного числа.

Вывод один: методика важнее инструмента. Практика — CI-гейт на дублирование и churn; измерять системный эффект, а не ощущение.

risk-triad: «когда AI да / нет» = вероятность × влияние × обнаружимость

1. Вероятность ошибки

низкая → высокая

растёт с незнакомостью задачи (ось SWE-bench Pro)

2. Влияние ошибки

низкое → высокое

необратимость, безопасность, деньги, данные

3. Обнаружимость

низкая → высокая

есть ли тест-оракул, SAST, ревью, которые поймут ошибку

Зона допустимого vibe-coding

ТОЛЬКО низкая × низкая × высокая (низкая вероятность × низкое влияние × высокая обнаружимость). Любая другая комбинация → дисциплина. Оси перемножаются, не складываются.

Триада подсказывает, что чинить:

- влияние ↑ → жёсткий человеческий гейт, потолок автономии вниз
- обнаружимость ↓ → добавить машинный оракул
- вероятность ↑ → senior-ревью

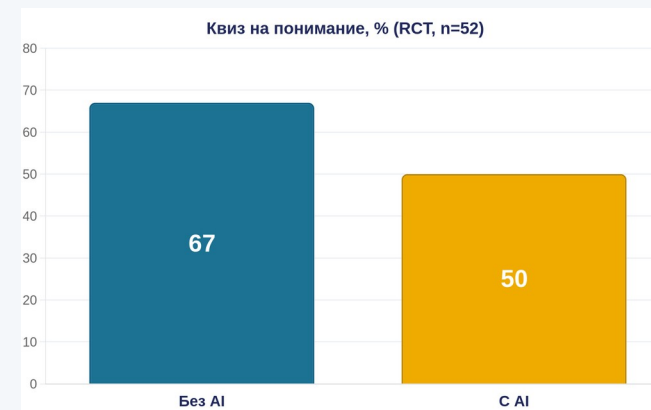
Böckeler ^[1]: «использование генеративного AI — постоянная оценка риска». Провал — vibe-coding «по ощущению»: игнор всех трёх осей. В нём сходятся все кейсы лекции: Replit (влияние ↑), curl-slop (обнаружимость ↓), уязвимый код (вероятность ↑).

Чек-лист «когда AI да / когда нет» + что это значит лично для вас

- ✓✓ 1. Какая это фаза жизненного цикла?
- ✓✓ 2. Можно ли решить без AI (детерминированно)? Да → не добавляйте AI
- ✓✓ 3. Существенная или привнесённая сложность? Существенная → человек

✓✓ 4. **Обратимо ли последствие? Необратимое → жёсткий человеческий гейт — ВЕТО-ось**

- ✓✓ 5. Есть ли машинный оракул (тест, SAST, прогон)? Нет → не доверять
- ✓✓ 6. Затронуты секреты / недоверенный контент? Да → least-priv + изоляция
- ✓✓ 7. Кто ревьюит и мержит? Merge и accountability — всегда человек
- ✓✓ 8. Цель — артефакт или навык? Навык → не делегировать генерацию



Anthropic, Shen & Tamkin 2026 (RCT, n=52, освоение незнакомой библиотеки) ^[1]: группа с AI на квизе 50% против 67% без AI (~-17 п.п.). Кто делегировал генерацию — просел; кто спрашивал концепции («как работает, почему») — деградации нет. Ускорение статистически не значимо.

Чек-лист — распределение бремени доказательства, не «всегда меньше AI»: для подходящей задачи он приведёт к высокой автономии. Необратимость и влияние — вето-ось. При обучении писать должны вы, роль AI — объяснять и проверять.

AI меняет цену написания кода — не цену понимания и ответственности

AI меняет цену написания кода, но не цену понимания, что строить и кто за это отвечает. Он касается каждой фазы по-разному — и надёжность даёт не инструмент, а дисциплина по фазам.

Метод переносится на все отрасли (не список инструментов):

- 1 разложить деятельность на фазы
- 2 спросить: привнесённая или существенная сложность
- 3 потребовать базу для каждого числа и системный эффект
- 4 отделить устойчивый паттерн от вендор-хайпа пятью вопросами

Семинар 4 — примените чек-лист к реальным кейсам своими руками.

Вопросы?

